

Лабораторно упражнение №4

Прилагане и администриране на IDS системи

1. Кратки сведения

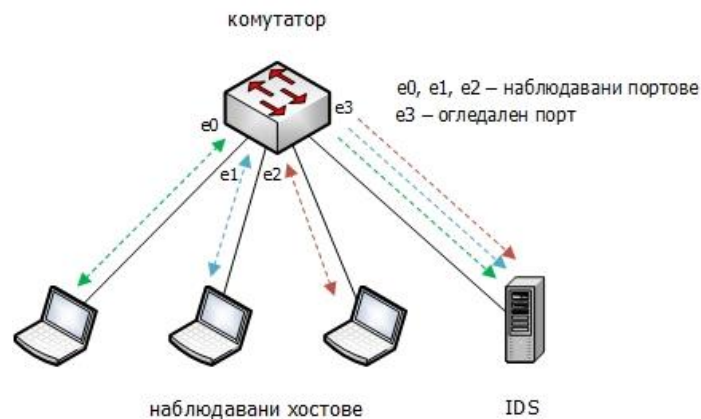
Системите за откриване на нарушения в сигурността (*Intrusion Detection Systems, IDS*) са предназначени за прихващане и анализ на мрежовия трафик, търсейки потенциални подозрителни дейности в мрежата. В основата си, една IDS представлява програмно приложение, прихващащо мрежовия трафик с цел анализ в реално време. При нужда от допълнителен, по-обстоятелствен анализ, IDS съхранява прихванатия трафик и генерира широк спектър от логове. Обобщаването и анализът на логовете спомага за решаване на редица проблеми свързани със сигурността, между които:

- нарушения в политиката за сигурност на мрежата, като системи и потребители, които са стартирали софтуерни приложения в противоречие с политиката;
- злонамерени софтуерни компоненти, които имат частичен или цялостен контрол върху вътрешни системи, използвайки ги, за да се разпространят или да атакуват други системи;
- изтичане на информация поради внедряване на шпионски софтуер и приложения за запис на клавишни последователности (keyloggers), както и случайно изтичане на информация от обикновени потребители.
- грешки в конфигурациите, като приложения или системи с некоректни настройки на сигурността или неправилни мрежови конфигурации, които намаляват производителността на мрежата. Към тази категория попадат и грешно конфигурирани защитни стени, където наборът от правила не отговаря на политиката за сигурност;
- неоторизирани клиенти или сървъри, включително сървърни приложения за самата мрежа като DHCP или DNS услугите, както и неоторизирани приложения като мрежови сканиращи инструменти или незащитен отдалечен самостоятелен компютър.

Според своите функционални възможности за противодействие, системите се делят на пасивни и реактивни. При пасивните IDS, в случай на откриване на потенциален пробив в сигурността, системата генерира логове с информация за събитията и изпраща алармени предупреждения в конзолни терминали, мобилни приложения и т.н. В реактивните системи, познати още като системи за предотвратяване на нарушения (*англ. Intrusion Prevention System, IPS*), системата автоматизирано отговаря на подозрителни събития, като прекъсва връзката и/или създава/променя правила в защитните стени за блокиране на мрежовия трафик.

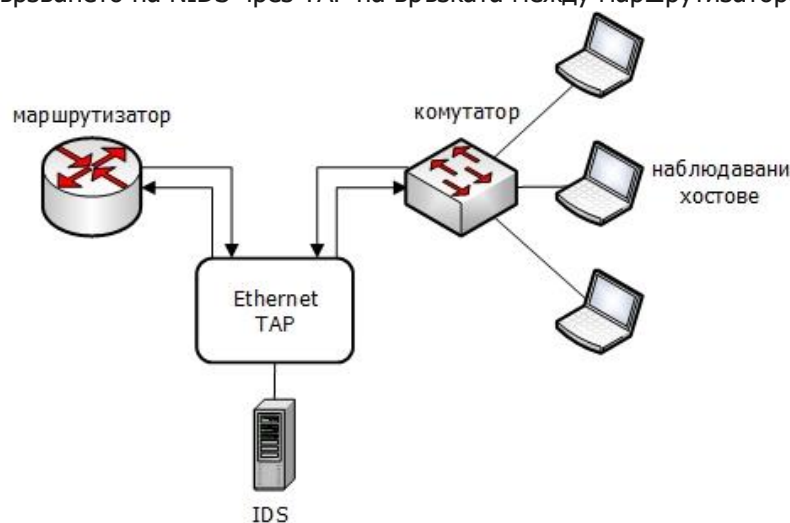
Според обхвата на действие, системите за откриване на нарушения се делят на хост-базирани IDS (HIDS) и мрежово-базирани IDS (NIDS). Хост-базираните IDS се стартират като системна услуга или агент върху защитавания хост, като HIDS не инспектира трафик, който не е предназначен за хоста. Вместо това, HIDS агентите наблюдават системни файлове, регистри, файлови контролни суми или други параметри, дефинирани в системата. Мрежово-базираните IDS извършват наблюдение над цялата мрежа за подозрителни трафични потоци чрез анализиране на протоколната активност. С цел инспекция на целия мрежов трафик, всички пакети трябва да бъдат дублирани и насочени към NIDS. Подходящо решение на този проблем

представяват огледалните портове (port mirroring), поддържани от управляемите комутатори, фиг.1.1. Основен недостатък на огледалните портове е загубата на данни, в случаите когато сумарните трафични обеми преминаващи през наблюдаваните портове надвишават капацитета на самия огледален порт.



Фиг.1.1. Използване на огледални портове за дублиране на мрежов трафик

Един от начините за избягване на трафичното претоварване на огледалните портове при комутаторите е използването на TAP (Test Access Point), което позволява разклоняването на мрежовия трафик, преминаващ през стандартните медни и оптични преносни среди. На фиг.1.2 е изобразено свързването на NIDS чрез TAP на връзката между маршрутизатора и комутатора.



Фиг.1.2. Свързване на NIDS посредством TAP устройство

Основните две категории от методи за откриване на нарушения в сигурността са методи базирани на сигнатури и методи базирани на аномалии:

- **Сигнатурно-базираните методи** се отнасят до откриване на атаки чрез търсене за специфични модели от пакетни или байтови последователности в мрежовия трафик (признаци за атаки), както и последователности от действия и инструкции, използвани от зловердни софтуерни приложения (malware).
- **Методите базирани на аномалии** имат за задача да откриват неизвестни типове атаки. Основният подход е използване на машинно обучение за създаване на модели от поведения, които са разрешени в мрежата, след което те се сравняват с текущите такива в реално време.

2. Suricata IDS

Suricata (suricata-ids.org) е система с отворен код за откриване и превенция на нарушения в мрежата, разработвана от Open Information Security Foundation (OISF). Енджинът на Suricata е в състояние да открива пробиви в сигурността в реално време, както и да предприема действия за предотвратяване на пробиви и офлайн анализ на прихванат **pcap** трафик. Бидейки сигнатурно-базирана IDS, Suricata инспектира мрежовия трафик на базата на предефинирани правила (сигнатури), като е възможно нови правила да бъдат добавяни в последствие от администраторите. Всяко правило съдържа следните компоненти:

- **Действие** – определя какво действие ще бъде извършено при наличие на съвпадение на правилото с мрежовия трафик;
- **Заглавна част (хедър)** – дефинира протокол, IP адреси, TCP/UDP портове и трафичната посока (възходяща/низходяща) на правилото;
- **Опции на правилото** – описва специфични параметри и съдържание на мрежовите пакети, с които се търси съвпадение.

Пример:

действие протокол източник и получател (IP адреси) портове на източника и получателя опции

drop tcp \$HOME_NET any -> \$EXTERNAL_NET any (msg:"ET TROJAN Likely Bot (EN +..)"; flow:established,to_server; flowbits:isset,is_proto_irc; content:"NICK "; pcre:"/NICK .*EN.*[0-9]{3,}/i"; reference:url,doc.emergingthreats.net/2008124; classtype:trojan-activity; sid:2008124; rev:2;)

2.1. Действие

Валидните действия на правилата са:

- **alert** – генерира предупредително съобщение, че е намерено съвпадение
- **pass** – прекратява по-нататъшна инспекция на пакета
- **drop** – отхвърля пакета и генерира предупредително съобщение
- **reject** – изпраща RST/ICMP unreachable грешка на изпращащият пакета, чието съвпадение с правилото е открито
- **rejectsrc** – същото като reject
- **rejectdst** – изпраща RST/ICMP съобщение за грешка към получателя на пакета
- **rejectboth** – изпраща RST/ICMP съобщение за грешка и на двете страни от връзката

2.2. Протокол

Описва пакет на кой протокол ще се инспектира от правилото. Налични са четири базови протоколи: **tcp**, **udp**, **icmp**, и **ip**. Използването на ip в дадено правило означава че важи за всеки пакет. Съществуват също и допълнителни дефиниции на протоколи от приложния слой, които могат да се използват за дефиниране на по-специфични правила:

- | | | |
|------------------|----------|---------|
| ▪ http | ▪ imap | ▪ dhcp |
| ▪ ftp | ▪ modbus | ▪ rfb |
| ▪ tls (вкл. ssl) | ▪ dnp3 | ▪ rdp |
| ▪ smb | ▪ enip | ▪ snmp |
| ▪ dns | ▪ nfs | ▪ tftp |
| ▪ dcerpc | ▪ ikev2 | ▪ sip |
| ▪ ntp | ▪ krb5 | ▪ http2 |
| ▪ smtp | | |

Наличността на тези приложни протоколи за дефиниране в правила зависи от това дали те са разрешени в основният конфигурационен файл на Suricata (suricata.yaml).

2.3. Адреси на източник и получател

Първата част (\$HOME_NET) представлява източника на трафик, а втората (\$EXTERNAL_NET) получателя. Посоката на трафика се определя от стрелката (->). Променливите \$HOME_NET и \$EXTERNAL_NET се дефинират в suricata.yaml и представляват мрежови адреси. При дефиниране на правилата, за източник и получател могат да бъдат използвани директно мрежови IP адреси (IPv4 и IPv6), които могат да бъдат комбинирани чрез оператори, табл. 1 и 2.

Таблица 1. Оператори за дефиниране на източник и получател в правилата

Оператор	Описание
../..	мрежов адрес (CIDR нотация)
!	отрицание (изключение)
[.., ..]	групиране

Таблица 2. Примери за дефиниране на източник и получател

Пример	Значение
! 1.1.1.1	всеки IP адрес освен 1.1.1.1
![1.1.1.1, 1.1.1.2]	всеки IP адрес освен 1.1.1.1 и 1.1.1.2
[\$EXTERNAL_NET, !\$HOME_NET]	важи за адреси от EXTERNAL_NET, но не и за адреси от \$HOME_NET
[10.0.0.0/24, !10.0.0.5]	всеки адрес от 10.0.0.0/24 без 10.0.0.5

Забележка: При дефиниция на променлива в yaml файл, означаваща всеки адресен обхват (any), напр: "HOME_NET: any", записите от вида "EXTERNAL_NET: !\$HOME_NET" са невалидни (not any).

2.4. Портове

В случаи на правила, конкретизирани за TCP и UDP, двете полета дефинират портовете на източника и получателя. Често използван аргумент е „any” означаващ всеки порт. Например, правило **any -> 80** важи за връзки с произволен порт на източника, които са насочени към HTTP порта на получателя. Подобно на IP адресите на източника и получателя, при портовете също се използват комбиниращи оператори, табл. 3 и 4.

Таблица 3. Оператори за дефиниране на портове на източник/получател

Оператор	Описание
:	обхват от портове
!	отрицание (изключение)
[.., ..]	групиране

Таблица 4. Примери за дефиниране на портове

Пример	Значение
[22,80,443]	Важи за портове 22,80,443
100:150	Важи за обхвата от порт 100 до порт 150
!80	Всеки порт без 80
[80:100,!99]	Обхват на портовете от 80 до 100 без 99
[1:80,!2,4]	Обхват на портовете от 1 до 80 без 2 и 4

2.5. Посока на трафика

Всяко правило притежава означение за трафичната посока от източник до получател, за която да важи то. Повечето правила притежават структура **source -> destination**, но в някои случаи е възможно използването на двупосочен означител **<>**, определящ, че се търси съвпадение, както във възходяща, така и в низходяща посока.

2.6. Опции на правилото

Останалата част от правилото се състои от опции. Те се затварят в скоби и се отделят чрез точка и запетая. Някои опции притежават собствени стойности / настройки (напр. опцията **msg**). Настройките в рамките на дадена опция се разделят чрез двоеточие (:):

(**опция1:стойност1;опция2:стойност2;опция3 ..**)

Някои от най-често използваните опции са:

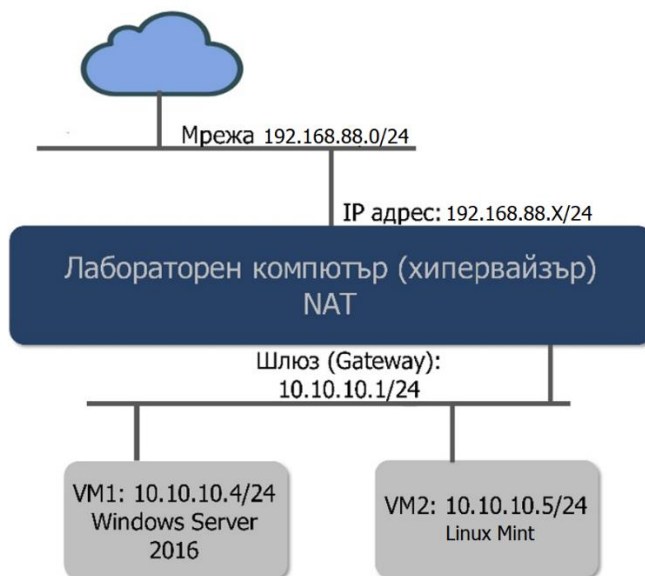
- **msg** (message) – опцията дава пояснителна информация за правилото и се отразява в предупредителното съобщение при съвпадение:
msg:"Telnet exploit detected";
- **sid** (signature ID) – всяко правило притежава собствен уникален идентификатор в рамките на IDS системата:
sid:200001;
- **rev** (revision) – идентификаторът (sid) често е придружен от опцията **rev**, показваща версията на правилото. Ако правилото се модифицира, опцията се увеличава с единица:
rev:3;
- **priority** – определя приоритета на правилото. Приема стойности от 1 до 255, като по-ниските стойности са по-високоприоритетни, и ще бъдат проверени за съвпадение с предимство.
priority:10;
- **metadata** – позволява да се специфицира допълнителна нефункционална информация за правилото.

2.7. Примери за правила

- **drop tcp any any -> 192.168.1.0/24 22 (msg:"SSH attempt at 192.168.1.0/24"; sid:1000001; rev:1;)** – правилото дефинира, че всички SSH заявки (порт 22) към хостове от мрежа 192.168.1.0/24 ще бъдат отхвърляни (drop);
- **alert tcp 192.168.1.0/24 any -> any 443 (msg:"Host from 192.168.1.0/24 attempts external HTTPS connection"; sid:1000002; rev:1;)** – генерира предупредително съобщение (alert), че хост/хостове от мрежа 192.168.1.0/24 правят опит за осъществяване на HTTPS връзка на TCP порт 443;
- **alert tcp 192.168.1.0/24 21 -> any any (msg:"FTP failed login"; content:"Login or password incorrect"; sid:1000003; rev:2;)** – генерира предупредителното съобщение „FTP failed login“ при откриване на съдържание в пакета „Login or password incorrect“ като отговор от FTP сървър(и), намиращи се в мрежа 192.168.1.0/24.

3. Лабораторна среда

В текущото упражнение ще бъде инсталирана, конфигурирана и тествана IDS системата Suricata върху виртуалната машина с Windows Server 2016. Тестовите на работоспособността на системата ще бъдат извършени с помощта на виртуалната машина с Linux Mint.



Фиг.3.1. Виртуализационна среда

4. Инсталация на Suricata IDS

- 1) Стартирайте виртуалните машини с Windows Server 2016 и Linux Mint и проверете свързаността помежду им, както и интернет връзката.
- 2) Suricata IDS е базирана на прихващане на трафик от мрежовия интерфейс, като използва Npcap драйвера. Инсталирайте драйвера **npcap-1.71.exe** във виртуалната машина с Windows Server 2016, като в Installation Options поставите отметка на „**Install Npcap in WinPcap API-compatible Mode**“. *Забележка: В случай, че на виртуалната машина има предварително инсталиран Wireshark (който е базиран на Npcap драйвера), то Npcap е вече инсталиран, но все пак трябва да бъде заменен с версия 1.71.*
- 3) Инсталирайте IDS системата **Suricata-6.0.8-1-64bit.msi** в **C:\Suricata** (вместо в \Program Files\).
- 4) Рестартирайте виртуалната машина с Windows Server 2016.
- 5) Верифицирайте инсталацията като стартирате команден промпт и въведете:

```
cd c:\suricata
suricata.exe
```

При успешна инсталация ще бъде изведен помощен списък с възможните аргументи/ключове към командата.

5. Базови настройки и основни аргументи и параметри

- 1) Използвайки помощния списък с аргументите на Suricata извършете следното:
 - Инсталирайте Suricata като услуга (Service), която ще позволи стартирането на системата при зареждане на операционната система.
 - Изведете списък с поддържаните режими на работа на системата (runmodes).

- Изведете списък с поддържаните протоколи на приложния слой.
- 2) Използвайки подходящ текстов редактор (напр. Sublime Text или Notepad++) редактирайте файла **C:\Suricata\suricata.yaml**, като зададете стойност на **HOME_NET: "10.10.10.0/24"** – адреса на защитавана мрежа, в която ще бъде следено за нарушения (представлява вътрешната NAT мрежа свързваща виртуалните машини).
 - 3) Разгледайте следните конфигурационни редове (в **suricata.yaml**) и се уверете, че са разрешени (**enabled: yes**) следните настройки:
 - **-stats** (ред 61): логва широк набор от параметри, като брой прихванати пакети, брой TCP връзки, брой генерирани предупреждения и т.н.
 - **-fast** (ред 77): позволява логване на събития в съкратен формат (на един ред);
 - **-http-log** (ред 304): логва всички HTTP заявки;
 - 4) Създайте директория **logs** на **C:**, в която ще бъдат съхранявани лог файловете на Suricata. Укажете директорията в **suricata.yaml** (ред 58).

6. Настройка на правилата за детекция на нарушения в Suricata IDS

Suricata се инсталира с включени само базови правила за инспектиране на трафик, разположени в **C:\Suricata\rules**. Файловете са с разширение ***.rules** и могат да бъдат модифицирани с текстов редактор. В допълнение, съществуват редица бази данни предоставящи хиляди допълнителни правила, които са на разположение за използване от всяка Suricata IDS система. В текущото упражнение ще бъдат използвани правилата на Emerging Threats.

- 1) Изтеглете правилата на Emerging Threats посредством <https://rules.emergingthreats.net/open/suricata-5/emerging.rules.tar.gz>. Разархивирайте правилата и поместете файловете в **C:\Suricata\rules**. Укажете директорията **C:\\Suricata\\rules** в **suricata.yaml** (ред 1888).
- 2) В допълнение, Suricata дава възможност за дефиниране на собствени правила (по формата, посочен в т.2 от теоретичната част), които се попълват във файл с наименование **local.rules**. Създайте файла в **C:\Suricata\rules** и го добавете към списъка с правилата в **suricata.yaml** (ред 1890).
- 3) Въведете следното тестово правило в **local.rules**:

alert icmp any any -> any any (msg:"ICMP Packet found"; sid:1000001; rev:1;)

Правилото ще генерира предупреждение при получаване на ICMP ping пакет.

- 4) Suricata включва вграден инспектор за предефинирани файлови идентичности, базирани на файловете сигнатури в шестнадесетична нотация. Те спомагат за идентифицирането на типовете файлове обменяни в мрежата. Сигнатурите се намират във файл **magic.mgc** в директорията на Suricata. Променете пътя до файла в **suricata.yaml** (ред 1079) и премахнете коментара.
- 5) В системата е включен класификатор на правила, чиито конфигурационен файл (**classification.config** в директорията на Suricata) съдържа описателна информация, която позволява генерираните аларми от правилата да бъдат по-лесно идентифицирани и приоритизирани. Укажете пътя до файла в **suricata.yaml** (ред 1958). В допълнение, Suricata поддържа файл със списък, съдържащ съкращения на URL адреси на бази данни с известни уязвимости, които съкращения могат директно да бъдат използвани при създаване на нови правила. Укажете пътя до файла (**reference.config** в директорията на Suricata) в **suricata.yaml** (ред 1959).

7. Проверка на работоспособността

- 1) Валидирайте конфигурационния файл (аргумент -T):

```
suricata -c suricata.yaml -T
```

При успешно валидиране ще бъде изведено съобщението: „**Configuration provided was successfully loaded. Exiting.**”

- 2) Стартирайте IDS системата като посочите пътя до конфигурационния файл и IP адрес на интерфейса, чиито трафик ще бъде инспектиран:

```
suricata -c suricata.yaml -i 10.10.10.4
```

- 3) Използвайте командата **ping 10.10.10.4** в Linux Mint и проверете регистрира ли се предупреждение (в **C:\logs\fast.log**) на базата на правилото за ICMP пакетите, което добавихте по-рано.
- 4) Прекратете изпълнението на Suricata и самостоятелно въведете правило в local.rules, чрез което да бъдат регистрирани опити за SSH заявки към виртуалната машина с Windows Server 2016.
Стартирайте отново Suricata и направете опит за SSH връзка от виртуалната машина с Linux Mint към виртуалната машина с Windows Server 2016 (*ssh administrator@10.10.10.4*).
- 5) Заредете страницата <http://sit.tu-varna.bg> (в Windows Server 2016) и проверете дали заредените уеб ресурси са отразени в http.log.